

Task -8

By Akshai S

Date:29/10/25

Intro

This lab walks through the TryHackMe **idsevasion** exercise to explore how Intrusion Detection Systems (IDS) behave under different reconnaissance and web-scanning patterns. We treated the environment as an authorised learning sandbox all activity was limited to the TryHackMe lab VMs. The goal wasn't to teach evasion as an offensive capability it was to observe how Suricata (NIDS) and Wazuh (HIDS) detect, log, and classify suspicious traffic and to document defensive takeaways.

In short, we scanned, probed, watched alerts, collected evidence (pcaps, logs, screenshots), and produced actionable recommendations for defenders.

What we actually did

- **Set up the lab.**

We started by launching the target machine on TryHackMe and creating a lab account. The room provided a web dashboard at `http://MACHINE_IP:8000/alerts` where all IDS alerts could be viewed. It took a few minutes for the lab environment to fully load.

- **Scanned the network (Nmap).**

We used the command `nmap -sV` to find open ports and identify running services. This helped us understand what was active on the machine. The IDS (Suricata and Wazuh) immediately detected these scans, showing how “normal” scans look in the alert system.

- **Checked for Grafana service.**

We found a web service running on port 3000 which was Grafana. By checking the page footer, headers, and the `/api/health` endpoint, we could see which version of Grafana was installed. We noted the version for later CVE (vulnerability) lookup.

- **Ran (Nikto).**

Next, we used the tool **Nikto** to scan the web services. The command `nikto -p 80,3000 -h MACHINE_IP` ran a full scan and generated thousands of alerts (~7000). Then

we tuned the scan to focus only on port 3000 and specific categories to reduce noise. We also changed the User-Agent string to make it less obvious, but found that some “evasion” options actually caused *more* alerts due to broken or weird requests.

- **Compared stealth vs aggressive scanning.**

We ran three types of scans default, tuned, and stealthy and compared how many alerts were generated. The result: slower and targeted scans triggered fewer alerts, but hiding too much also made the scan less effective. Basically, the quieter you try to be, the less info you get.

- **Collected and matched evidence.**

During all tasks, we saved packet captures (pcaps), IDS alert screenshots, and log files. We matched timestamps between the pcaps and alerts to see exactly which actions triggered which detections. This correlation became the main evidence for our analysis and report.

Result:

The test was completed successfully, and we were able to capture the root flag {SNEAK_ATTACK_CRITICAL}. The IDS detected our early scans and basic access attempts, showing that it was working as expected. After adjusting our scanning methods and being more careful, we managed to finish the rest of the steps without triggering any more alerts. This shows that while the IDS can catch obvious activity, it can still miss well-planned or quiet actions.

